

InfoJOB

Resposta ao Parecer Técnico de Segurança

Versão analisada: 2.2.0 → Versão corrigida: 2.2.4 | Julho de 2026 | TRT18 / TRT19

Este documento apresenta as medidas adotadas em resposta aos achados do Parecer Técnico de Segurança emitido para fins de autorização de uso corporativo da extensão InfoJOB. Todas as correções foram implementadas na versão 2.2.4, disponível para instalação via Chrome Web Store.

4.1 — Injeção de HTML/XSS ■ CORRIGIDO

Severidade original: Crítico

Implementada função `escapeHtml()` em `popup.js` e `content.js`. Todos os pontos onde dados provenientes da planilha (nome, processo, erro) ou do nome de arquivo eram interpolados via `innerHTML` foram corrigidos — os valores passam agora pelo escape de entidades HTML antes de qualquer inserção no DOM. Pontos corrigidos: função `log()` e `exibirResultado()` no `popup`; `exibirModalResultado()` no `content script`.

4.2 — Distribuição fora da Chrome Web Store ■ JÁ RESOLVIDO

Severidade original: Médio

A extensão já foi publicada na Chrome Web Store (ID: `enmjphhfnmeanmdpobkkmccjlnbhgdck`) e aprovada após revisão da equipe do Google. Para implantação corporativa centralizada, está disponível um script PowerShell (`instalar_infojob.ps1`) que registra a extensão via `ExtensionInstallForcelist`, garantindo instalação e atualização automáticas gerenciadas pela TI.

4.3 — web accessible resources exposto a qualquer site ■ CORRIGIDO

Severidade original: Médio

O bloco `upload/*`, `ajuda/*` e o guia PDF que utilizavam `<all_urls>` foram restritos exclusivamente aos domínios do eCAC (`cav.receita.fazenda.gov.br`, `www3.cav.receita.fazenda.gov.br`, `servicos.receita.fazenda.gov.br`), eliminando o vetor de `fingerprinting` e `clickjacking` por sites externos.

4.4 — Chamada de rede externa ao Google Fonts ■ CORRIGIDO

Severidade original: Baixo

As importações de `fonts.googleapis.com` foram removidas de `popup.html` e `options.html`. As fontes IBM Plex Sans e IBM Plex Mono foram embutidas localmente no pacote da extensão (pasta `fonts/`, arquivos `.woff2` ~350KB), preservando o visual original sem nenhuma chamada de rede para servidores de terceiros. A afirmação de processamento local é agora literalmente verdadeira.

4.5 — Documentação hospedada em conta pessoal do GitHub ■ PARCIALMENTE RESOLVIDO

Severidade original: Baixo

O repositório está público em github.com/Rodrigo-Madalosso-Araujo/infojob. A migração para repositório institucional depende de decisão de governança do tribunal. Os links de documentação acessíveis dentro da extensão apontam para recursos embutidos no próprio pacote instalado, não para URLs externas — uma eventual indisponibilidade do GitHub não afeta o funcionamento da extensão.

4.6 — Bibliotecas quebradas presentes no pacote ■ CORRIGIDO

Severidade original: Informativo

Os arquivos `libs/html2canvas.min.js`, `libs/jspdf.umd.min.js` e `popup/xlsx.full.min.js` — que continham apenas o texto "Host not in allowlist" e não eram referenciados por nenhum script ativo — foram removidos do pacote.

Permissões — Ajustes Realizados

Permissão windows — REMOVIDA ■

A chamada `chrome.windows.update()` foi substituída por `chrome.tabs.update()` com `active: true`, eliminando completamente a necessidade da permissão windows. A permissão foi removida do `manifest.json`.

Permissão tabs — MANTIDA com justificativa ■

A permissão tabs é utilizada de forma extensiva e necessária: `tabs.query` para localizar a aba ativa do eCAC, `tabs.create` para abrir o guia do usuário, `tabs.update` para navegar entre páginas, e `tabs.sendMessage` para comunicação com os content scripts. Sua remoção inviabilizaria o funcionamento central da extensão. Os `host_permissions` já restringem o scripting exclusivamente aos domínios da Receita Federal.

Resumo das Correções — v2.2.4

Achado	Severidade	Status
XSS via innerHTML (popup e content script)	Crítico	■ Corrigido
Distribuição fora da Chrome Web Store	Médio	■ Já resolvido (Store)
<code>web_accessible_resources</code> com <code><all_urls></code>	Médio	■ Corrigido
Permissão windows desnecessária	Médio	■ Removida
Chamada externa ao Google Fonts	Baixo	■ Corrigido (fontes locais)
Documentação em repositório pessoal	Baixo	■ Pendente (governança)
Bibliotecas quebradas no pacote	Informativo	■ Corrigido
Permissão tabs ampla	Médio	■ Mantida — necessária

Conclusão

Dos 7 achados com ação técnica possível, 6 foram integralmente corrigidos na versão 2.2.4, incluindo o único achado de severidade crítica (XSS). O achado 4.4 (Google Fonts) foi resolvido de forma mais robusta que o inicialmente previsto: em vez de substituir por fontes do sistema, as fontes foram embutidas localmente no pacote (.woff2), preservando o visual original e tornando a extensão verdadeiramente autossuficiente. O único item pendente (4.5 — repositório pessoal) depende de decisão institucional de governança e não representa risco operacional.

A versão 2.2.4 atende plenamente às condições estabelecidas no parecer para autorização corporativa.

InfoJOB v2.2.4 — Desenvolvido para uso no Poder Judiciário

Rodrigo Madalosso Araujo (TRT18) · Leandro Vinícius de Magalhães Rodrigues (TRT19)